Master Direction on Information Technology Governance, Risk and Controls

SYNTHETIC DEMONSTRATION DOCUMENT. Modelled on the structure of banking regulation for evaluation purposes only. Not an actual regulatory instrument.

Synthetic Regulatory Authority

SYN/ITG/2024/03

Dated: March 20, 2024

The Synthetic Regulatory Authority issues these Directions to strengthen IT governance and cyber resilience. These Directions shall come into force on July 1, 2024.

CHAPTER I - Preliminary

1. Short Title

1.1 These Directions shall be called the Master Direction on IT Governance.

CHAPTER II - IT Governance

2. Board Oversight

2.1 The RE shall constitute an IT Strategy Committee of the Board which shall meet at least once every quarter.

2.2 The RE shall appoint a Chief Information Security Officer (CISO) who shall report directly to the Executive Director or equivalent.

CHAPTER III - Access Control

3. Privileged Access

3.1 The RE shall implement multi-factor authentication for all privileged users accessing critical systems.

3.2 User access rights to critical systems shall be reviewed at least once every quarter.

3.3 Privileged access sessions shall be logged and the logs shall be retained for at least 180 days.

CHAPTER IV - Vulnerability and Patch Management

4. Patching and Testing

4.1 Critical security patches shall be applied to all critical systems within 14 days of their release.

4.2 The RE shall conduct vulnerability assessment and penetration testing (VA/PT) of all critical systems at least once a year.

CHAPTER V - Business Continuity

5. Disaster Recovery and Backup

5.1 The RE shall conduct disaster recovery drills for critical systems at least once every six months.

5.2 Backups of critical data shall be taken daily.

5.3 Restoration of backups shall be tested at least once every quarter.

CHAPTER VI - Incident Management

6. Incident Reporting

6.1 The RE shall report every cyber security incident to the Authority within six hours of its detection.

6.2 The RE shall conduct a root cause analysis for every critical incident and place the report before

the Board within 30 days.

CHAPTER VII - Assurance

7. Information Systems Audit

7.1 The RE shall get an Information Systems audit conducted by an independent auditor at least once a year.